# B03 — Keamanan rantai pasok perangkat lunak

© 2026 Dea Saka Kurnia Putra. All rights reserved.

| Kontrol dokumen | |
|---|---|
| ID dokumen | B03 |
| Judul | Keamanan rantai pasok perangkat lunak |
| Versi | 0.1.0 (= versi aplikasi) · commit `1cec7e2` |
| Tanggal | 2026-10-24 |
| Status | Draf |
| Klasifikasi | Internal |
| Pemilik | Dea Saka Kurnia Putra |
| Penyusun | Dibangkitkan oleh `scripts/compliance/*` (Claude Code) dari sumber kebenaran repo |
| Penyetuju | [KONFIRMASI] — penyetuju dokumen belum ditetapkan |
| Lingkup | Repo DSKPutra/finandex, CI GitHub Actions, rilis |
| Standar acuan | NIST SP 800-218 (SSDF) — praktik PO/PS/PW/RV; SLSA (Build track); OpenSSF Scorecard; ISO/IEC 5230:2020; ISO/IEC 18974:2023 |
| Dokumen terkait | B01, B04, A09 |

### Riwayat perubahan

| Versi | Tanggal | Perubahan |
|---|---|---|
| 0.1.0 | 2026-10-24 | Versi pertama, dibangkitkan dari artefak SBOM rilis ini. |

## 1. Praktik yang diterapkan (bukti di repo)

| Praktik | Implementasi | Bukti |
|---|---|---|
| Lockfile & versi eksak | semua dependensi dipin persis ( `--save-exact` ); `npm ci` di CI & Vercel | package.json @ 1cec7e2, vercel.json#L4 @ 1cec7e2 |
| Tinjauan dependensi baru | versi dipilih ≥ 2 minggu sejak rilis; lisensi diperiksa | `npm run check:licenses` (ada), docs/DECISIONS.md |
| Kebijakan lisensi | tolak GPL/AGPL/SSPL di kode yang didistribusikan (§5.5 master prompt) | scripts/security/check-licenses.ts @ 1cec7e2 |
| Pemindaian secret | gitleaks di CI + pemindai pola kunci di bundel klien | .github/workflows/ci.yml#L39 @ 1cec7e2, `npm run check:secrets` |
| Audit kerentanan | `npm audit` + osv-scanner + grype atas SBOM; setiap temuan → VEX | .github/workflows/compliance.yml#L3 @ 1cec7e2 |
| Pembaruan dependensi | Dependabot | .github/dependabot.yml @ 1cec7e2 |

| Praktik | Implementasi | Bukti |
|---|---|---|
| Provenance build | actions/attest-build-provenance (setara SLSA Build L3 untuk runner GitHub-hosted) | .github/workflows/compliance.yml#L70 @ 1cec7e2 |
| Tanda tangan SBOM | Sigstore cosign keyless (OIDC) | scripts/compliance/sign-sbom.sh @ 1cec7e2 |
| Secret CI | hanya di GitHub Secrets / env platform; tidak pernah di repo atau bundel klien | server/env.ts#L6 @ 1cec7e2 |
| Tanda tangan aplikasi mobile/desktop | keystore Android & sertifikat Apple di GitHub Secrets (android.yml, ios.yml); Tauri updater bertanda tangan | .github/workflows/android.yml @ 1cec7e2, .github/workflows/ios.yml @ 1cec7e2 |

## 2. Celah yang tercatat

- OpenSSF Scorecard belum dijalankan otomatis — **belum diukur**.
- Versi paket Python referensi belum dipin (lihat B01 §5).
- 22 temuan di alat build (devDependencies) berstatus `not_affected` untuk artefak yang didistribusikan, tetapi tetap berisiko bagi lingkungan build — lihat B04 §2.

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex